

SIMATS ENGINEERING
ASSESSMENT TOOL I – APPLICATION-BASED QUESTIONS (High)

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name : SHAM S. 192325076

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

1. A mid-sized financial organization operates several legacy Windows servers where multiple RPC services remain exposed due to delayed patching cycles caused by operational constraints. Recently, abnormal traffic patterns and unauthorized connection attempts have been observed within the internal network. As a security analyst, evaluate how attackers could exploit these RPC vulnerabilities to gain unauthorized access and escalate privileges. Assess the level of risk associated with delaying patches in such environments and justify whether immediate patch deployment or controlled maintenance scheduling is more appropriate. Recommend suitable mitigation strategies to reduce exposure without affecting business continuity.
2. A web application used for online transactions suffers from multiple vulnerabilities, including cross-site scripting (XSS), cross-site request forgery (CSRF), and weak session management practices. Users report unauthorized transactions and session hijacking incidents. Evaluate how attackers could combine these vulnerabilities to execute complex attacks affecting user accounts. Assess the risks associated with poor session handling and lack of input validation. Justify the need for a layered security approach and recommend comprehensive mitigation strategies to secure the application.
3. An enterprise uses an outdated IIS server to host multiple internal and external applications, and recent vulnerability scans indicate several unpatched critical flaws. Despite warnings, the organization delays updates due to fear of downtime and service disruption. Assess how attackers could exploit these vulnerabilities to gain unauthorized access or execute remote code. Evaluate the risks associated with delaying security updates in such environments and justify whether immediate patching or temporary isolation is more appropriate. Recommend strategies to ensure both security and service availability.
4. A mobile application used by customers stores sensitive information such as login credentials and personal data in plaintext within the device storage. Additionally, the application communicates with backend servers over unsecured channels. Evaluate how attackers could exploit these weaknesses through device compromise or network interception. Assess the potential impact on user privacy and organizational reputation. Justify the need for encryption and recommend secure storage and communication techniques.
5. A system administrator disables the Windows firewall temporarily to troubleshoot connectivity issues but forgets to re-enable it. Within a short period, multiple unauthorized access attempts

are detected. Evaluate how attackers could exploit this temporary exposure to gain access to critical services. Assess the risks associated with mismanagement of security controls and justify the importance of enforcing automated policies. Recommend administrative safeguards to prevent such incidents.

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all requirements	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem	
Application of Concepts	30	Accurately applies appropriate concepts to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts	
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach	
Accuracy of Solution	20	Completely correct solution with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution	
Clarity	10	Clear, wellorganized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand	

1. Exploitation of Vulnerable RPC Services in Windows

Introduction

Remote Procedure Call (RPC) allows Windows systems and applications to communicate with services on other systems. If RPC services are exposed and remain unpatched, attackers may exploit known vulnerabilities to gain unauthorized access, execute malicious code, or move between systems.

In this organization, delayed patching has increased the attack surface because legacy Windows servers continue to expose vulnerable RPC services. **How attackers could exploit the vulnerabilities**

An attacker could follow a sequence such as:

Reconnaissance → Identify exposed RPC services → Identify vulnerable versions → Exploit vulnerability → Gain unauthorized access → Privilege escalation → Lateral movement

1. Reconnaissance

Attackers first identify systems that expose RPC-related services and determine which services and versions are running.

2. Vulnerability identification

The attacker compares the identified service versions with known vulnerabilities. Unpatched legacy systems are particularly attractive targets.

3. Initial exploitation

A vulnerable RPC service may allow an attacker to execute unauthorized actions or malicious code remotely, depending on the vulnerability.

4. Privilege escalation

After obtaining limited access, attackers may attempt to exploit additional weaknesses to obtain higher privileges, such as administrator-level access.

5. Lateral movement

A compromised server can become a starting point for accessing other internal systems, especially if network segmentation and access controls are weak.

Risk of delaying patches

Risk	Impact
Remote exploitation	Unauthorized access to servers
Privilege escalation	Attackers may obtain administrator privileges
Lateral movement	Compromise can spread internally
Data theft	Sensitive organizational data may be exposed
Malware/ransomware	Critical services may become unavailable

Compliance issues Security requirements may be violated

The risk is **high** because the vulnerabilities are already known and the abnormal traffic indicates possible attack activity.

Immediate patching or controlled scheduling?

Under normal circumstances, controlled maintenance scheduling can reduce operational disruption. However, in this situation, **immediate risk reduction should be prioritized** because:

- Critical vulnerabilities are unpatched.
- Suspicious connection attempts have already been observed.
- Legacy systems may be easier to exploit. • Delaying further increases exposure.

If immediate patching could seriously affect business operations, the organization should first apply **temporary compensating controls**, then patch during the earliest controlled maintenance window.

Mitigation strategies

1. Apply security patches after appropriate testing.
2. Restrict unnecessary RPC services.
3. Use firewalls to limit RPC access to trusted systems.
4. Segment critical servers from general user networks.
5. Monitor unusual RPC traffic.
6. Use IDS/IPS to detect suspicious activity.
7. Maintain an updated asset and vulnerability inventory.
8. Keep reliable backups.
9. Use least-privilege access.
10. Establish an emergency patching procedure for critical vulnerabilities.

Conclusion

Unpatched RPC services represent a **high security risk** because they may provide attackers with an entry point for unauthorized access, privilege escalation, and lateral movement. The organization should prioritize **rapid remediation**, using isolation and access restrictions as temporary controls when immediate patching could affect business continuity.

2. XSS, CSRF and Weak Session Management

Introduction

Web applications handling online transactions must protect authentication, user sessions and transaction requests. XSS, CSRF and poor session management can become particularly dangerous when they occur together.

The combination can allow attackers to compromise user sessions or manipulate authenticated actions.

How attackers could combine the vulnerabilities

A possible attack chain is:

Malicious input → XSS → User interaction/session information → Session compromise → CSRF/unauthorized transaction

1. Cross-Site Scripting (XSS)

XSS occurs when an application accepts untrusted input and displays it without proper validation or output encoding.

A successful XSS attack can cause malicious content to execute in a victim's browser under the application's security context.

2. Weak session management Poor

session management may include:

- Predictable session identifiers.
- Sessions that do not expire properly.
- Failure to invalidate sessions after logout.
- Inadequate cookie security.
- Excessively long session lifetimes.

These weaknesses increase the possibility of session hijacking.

3. Cross-Site Request Forgery (CSRF)

CSRF tricks an authenticated user's browser into sending an unwanted request to a website where the user is already logged in.

For example, an attacker could attempt to cause an authenticated user to unknowingly perform an account-related transaction.

4. Combined impact

If XSS, CSRF and weak session management exist together, the overall risk becomes significantly higher.

An attacker could potentially:

1. Deliver malicious content through an XSS vulnerability.
2. Target an authenticated user.
3. Abuse the application's session.
4. Cause unauthorized requests.
5. Potentially manipulate account or transaction functions.

Risks of poor session handling

- Account takeover.
- Session hijacking.
- Unauthorized transactions.
- Exposure of personal information.
- Identity theft.
- Financial loss.
- Loss of customer trust.

Risks of poor input validation

Poor input validation can allow malicious data to enter the application.

This can result in:

- XSS.
- Injection attacks.
- Unexpected application behavior.
- Data manipulation.

Need for layered security

A single security control is not sufficient. If one protection fails, another should provide protection.

Recommended layered approach

Input validation

↓

Output encoding

↓

Secure authentication

↓

Secure session management

↓ **CSRF protection**

↓

Security headers/WAF

↓

Logging and monitoring

Mitigation strategies

Against XSS

- Validate input.
- Encode output according to context.
- Use Content Security Policy (CSP).
- Avoid unsafe handling of user-supplied content.

Against CSRF

- Use anti-CSRF tokens.
- Use appropriate **SameSite** cookie settings.
- Verify the origin of sensitive requests.

For session security

- Use strong, unpredictable session identifiers.
- Use HTTPS.
- Set **Secure** and **HttpOnly** cookie attributes.
- Expire inactive sessions.
- Regenerate sessions after authentication.
- Invalidate sessions after logout.

Additional measures

- Multi-factor authentication.
- Web Application Firewall.
- Security testing.
- Regular vulnerability assessments.
- Transaction confirmation for high-risk operations.

Conclusion

XSS, CSRF and weak session management can combine to create a serious account compromise risk. A **layered security architecture** involving secure coding, strong session controls, CSRF protection, HTTPS, security headers and continuous monitoring is necessary to protect online transactions.

3. Outdated IIS Server and Unpatched Critical Vulnerabilities

Introduction

Internet Information Services (IIS) is a Windows web-server platform used to host web applications and services. An outdated IIS server with known critical vulnerabilities creates a significant attack surface.

Because the organization hosts both internal and external applications, compromise could affect multiple systems and services.

How attackers could exploit the weaknesses

A general attack path is:

Internet exposure → Service discovery → Vulnerability identification →

Exploitation → Unauthorized access/Code execution → Privilege escalation → Internal movement

1. Identify the server

Attackers may identify externally accessible IIS servers and determine the services and applications hosted on them.

2. Identify outdated components

The attacker may determine whether the IIS version or associated components contain known security weaknesses.

3. Exploit vulnerable services

If a known vulnerability permits unauthorized actions, an attacker could potentially gain access or cause unauthorized code execution.

4. Privilege escalation

If the compromised application operates with excessive privileges, attackers may attempt to increase their privileges.

5. Lateral movement

A compromised IIS server may provide access to other internal resources if network segmentation and access controls are inadequate.

Risks of delaying updates

Risk	Possible Impact
Known vulnerabilities	Easy target for attackers
Remote code execution of commands/code	Unauthorized execution
Data exposure	Sensitive information may be stolen
Malware	Server may be compromised
Service disruption	Applications may become unavailable
Lateral movement	Other systems may be targeted
Reputation damage	Customer trust may decrease

Immediate patching or temporary isolation?

Because the vulnerabilities are **critical and unpatched**, the preferred approach is:

Immediate remediation with controlled deployment

The organization should not indefinitely delay patching because of downtime concerns.

If immediate patching cannot be performed safely:

Temporary isolation → Risk reduction → Backup/testing → Emergency patching → Monitoring

Temporary isolation should therefore be treated as a **short-term compensating control**, not a permanent replacement for patching.

Strategies for security and availability

1. Test patches in a staging environment.
2. Maintain current backups.
3. Use a maintenance window for production updates.
4. Use redundant servers where possible.
5. Apply network segmentation.
6. Restrict unnecessary Internet access.
7. Use reverse proxies/WAF where appropriate.
8. Monitor IIS logs and suspicious activity.

9. Maintain a vulnerability management program.
10. Establish rollback procedures for failed updates.

Conclusion

Delaying critical IIS updates exposes the organization to potentially serious attacks, including unauthorized access and remote code execution. **Patching should be prioritized**, while temporary isolation, redundancy, backups and staged deployment can minimize downtime.

4. Mobile Application – Plaintext Storage and Unsecured Communication

Introduction

The mobile application stores login credentials and personal information in plaintext and communicates with backend servers through unsecured channels. These are serious security weaknesses because sensitive information can be exposed through both the device and the network.

Attack possibilities

The general attack paths are:

Device compromise → Access application storage → Obtain sensitive information

and

Unsecured communication → Network interception → Capture sensitive information

1. Plaintext storage

If sensitive information is stored directly on the device without protection, a compromised or improperly secured device may expose:

- Usernames.
- Passwords.
- Personal information.
- Authentication tokens. ● Application data.

An attacker who obtains access to application storage could potentially retrieve this information.

2. Unsecured communication

Communication without adequate encryption allows sensitive information to travel without sufficient protection.

A malicious party positioned on the communication path could potentially observe or manipulate transmitted information.

This can lead to:

- Credential exposure.
- Personal-data leakage.
- Session compromise.
- Data modification. ● Privacy violations.

Impact on users

The potential consequences include:

1. Account takeover.
2. Identity theft.
3. Exposure of personal information.
4. Financial loss.
5. Loss of privacy.

Impact on the organization

The organization may experience:

- Loss of customer trust.
- Reputation damage.
- Financial losses.
- Regulatory consequences.
- Increased support costs. ● Loss of business.

Need for encryption

Encryption protects information by converting readable data into protected data that cannot easily be understood without the appropriate key.

Two areas require protection:

Data at rest

Sensitive information stored on the device should be encrypted.

Data in transit

Communication between the mobile application and backend should use secure encrypted communication.

Secure storage techniques

- Do not store passwords in plaintext.

- Use secure platform-provided storage mechanisms.
- Encrypt sensitive application data.
- Store only information that is necessary.
- Protect authentication tokens.
- Use appropriate key-management mechanisms.

Secure communication techniques

- Use HTTPS/TLS.
- Validate server certificates.
- Avoid transmitting sensitive data through insecure protocols.
- Use strong authentication between application and backend.
- Apply secure API design principles.

Conclusion

Plaintext storage and unsecured communication create serious privacy and security risks. The application should use **secure storage, encryption, HTTPS/TLS, proper authentication and secure key management**. These measures protect users and help maintain the organization's reputation and compliance.

5. Windows Firewall Disabled

Introduction

A Windows firewall controls network traffic entering and leaving a system. Disabling it removes an important security layer. In this scenario, the administrator forgot to re-enable the firewall, creating unnecessary exposure to unauthorized connection attempts.

How attackers could exploit the exposure

A general attack path is:

Firewall disabled → Increased network exposure → Service discovery → Attempt exploitation → Unauthorized access → Privilege escalation

1. Increased exposure

When the firewall is disabled, services that would normally be restricted may become reachable.

2. Service discovery

An attacker may identify accessible network services.

3. Exploitation attempts

If an exposed service contains a vulnerability or uses weak authentication, an attacker may attempt unauthorized access.

4. Privilege escalation

If initial access is obtained, additional weaknesses could potentially allow the attacker to gain higher privileges.

5. Further compromise

A compromised machine may be used to access other internal resources if adequate segmentation is not present.

Risks of mismanaging security controls

Problem	Risk
Firewall left disabled	Increased attack surface
No automated verification	Human error remains undetected
Exposed services	Unauthorized access attempts
Weak configuration management	Security controls may remain inactive
Delayed response	Greater possibility of compromise

The incident demonstrates that **human error can undermine technical security controls**.

Importance of automated policies

Security controls should not depend completely on administrators remembering manual actions.

Automated policies can:

- Automatically enforce firewall configuration.
- Detect unauthorized configuration changes.
- Alert administrators when security controls are disabled.
- Restore approved security settings.
- Maintain centralized security policies.
- Record configuration changes for auditing.

Administrative safeguards

1. Change-management procedures

Temporary security changes should have an approved change request and defined expiration time.

2. Automatic re-enablement

Where practical, temporary troubleshooting changes should automatically expire.

3. Centralized policy management

Use centralized Windows security policies to enforce firewall settings.

4. Continuous monitoring

Security monitoring should alert administrators when a firewall becomes disabled.

5. Least privilege

Only authorized administrators should be able to modify critical security settings.

6. Regular audits

Periodically verify that firewalls and other security controls are active.

7. Documentation

Administrators should document temporary changes and restore configurations after troubleshooting.

Conclusion

Disabling the Windows firewall temporarily can create a significant security gap if it is not restored. The incident demonstrates the importance of **automated security policies, centralized management, monitoring, least privilege and proper change-management procedures**. Security controls should be designed so that a simple human mistake does not leave a system exposed.

Final Summary for All 5 Questions

Question	Main Vulnerability	Risk	Main Mitigation
----------	--------------------	------	-----------------

1	Unpatched RPC	High	– unauthorized Patch, restrict RPC, services access and lateral segmentation, monitoring movement
---	---------------	------	---

- | | |
|---|--|
| 2 | XSS + CSRF + weak High – account takeover Input validation, output sessions and unauthorized encoding, CSRF tokens, transactions secure sessions, HTTPS |
| 3 | Outdated IIS High/Critical – Immediate patching, unauthorized access and isolation, testing, backups possible code execution |
| 4 | Plaintext storage + High – credential and Encryption, secure storage, insecure personal-data exposure HTTPS/TLS communication |
| 5 | Disabled Windows High – increased service Automated policies, firewall exposure monitoring, centralized management |

Overall Conclusion

The five scenarios demonstrate that security weaknesses can arise from **unpatched systems, insecure application design, poor data protection and misconfigured security controls**. Effective cybersecurity requires a **defense-in-depth approach** combining patch management, secure configuration, encryption, access control, network segmentation, monitoring and automated security policies. This reduces both the probability and impact of successful attacks while maintaining business continuity.